

Threat Modeling Lab - MegaTravel

Izveštaj po zadacima 1-5

Zadatak 1 - Motivacija napadača

MegaTravel obrađuje visoko osetljive podatke, uključujući:

- lične podatke korisnika (PII),
- podatke o platnim karticama,
- itinerare i lokacije korisnika u realnom vremenu,
- poslovne (B2B) ugovore.

Sa preko 100 miliona korisnika, sistem predstavlja **visokovrednu metu** za različite klase napadača.

Klasa napadača	Nivo veštine	Pristup	Ciljevi	Verovatnoća
Script kiddies	Nizak	Javni internet	Defacement, DoS, hvalisanje	Visoka
Cyber kriminalci	Visok	Internet + mito insajderima	Krađa kartica, PII, ransomware, BEC prevare	Visoka
Insajderi (zaposleni)	Srednji–Visok	Legitiman interni pristup	Krađa podataka, sabotaza, lična zloupotreba	Srednja
Konkurencija	Srednji–Visok	Javni endpoints, regrutovani insajderi	Cene, ugovori, baze kupaca	Srednja
Haktivisti	Srednji	Javni internet	DDoS, defacement (overtourism, klima)	Niska
Nation-state	Vrlo visok	Napredne tehnike	Praćenje meta (itinerari, lokacije)	Vrlo niska

Zadatak 2 - Imovina (Assets)

Kao što smo na predavanjima naučili, informacija predstavlja najskuplju robu te se očekuje da će napadači imati u interesu dolazak do najvrednijih podataka. U slučaju MegaTravel agencije, najosetljiviju imovinu predstavljaju:

1. **Podaci o klijentima** (imena, adrese, brojevi pasoša, istorija putovanja i preferencije 100 miliona korisnika)
 - a. inherentna izloženost (exposure): Zaposleni u korisničkoj podršci, administratori baza podataka, marketinški tim, klijenti putem web aplikacije
 - b. bezbednosni ciljevi (CIA):
 - i. poverljivost (confidentiality): visoka. Curenje podataka vodi do kršenja GDPR-a (General Data Protection Regulation - Opšta uredba o zaštiti podataka o ličnosti) i gubitka poverenja
 - ii. integritet (integrity): srednja. Neovlašćena izmena može dovesti do pogrešnih rezervacija
 - c. uticaj (impact): kritičan. Ogromne zakonske kazne, tužbe klijenata i trajno uništena reputacija brenda.
2. **Finansijski podaci i podaci o plaćanju** (brojevi kreditnih kartica, istorija transakcija, podaci o bankovnim računima kompanije)
 - a. inherentna izloženost: servis za plaćanje, finansijski sektor kompanije
 - b. bezbednosni ciljevi:
 - i. poverljivost: kritična. Krađa kartica direktno šteti klijentima
 - ii. integritet: kritična. Napadač bi mogao da menja iznose transakcija ili preusmerava uplate
 - c. uticaj: kritičan. Direktna finansijski gubitak, gubitak ovlašćenja za rad sa karticama i krivična odgovornost
3. **Sistem za rezervacije i dostupnost usluga** (softver koji povezuje letove, hotele i rent-a-car u realnom vremenu)
 - a. inherentna izloženost: svi korisnici na internetu, partnerske agencije, zaposleni
 - b. bezbednosni ciljevi:
 - i. dostupnost: kritična. Sistem mora raditi konstantno

- ii. integritet: visoka. Sprečavanje duplih rezervacija ili brisanja postojećih
- c. uticaj: visok. Svaki sat tokom kog sistem nije funkcionalan donosi milionske gubitke u neostvarenim prodajama
- 4. **Poslovni ugovori** (ugovori sa hotelima i prevoznicima)
 - a. inherentna izloženost: menadžment, pravni tim, prodajni agenti
 - b. bezbednosni ciljevi:
 - i. poverljivost: visoka. Konkurencija može iskoristiti ove informacije za preuzimanje tržišta
 - c. uticaj: srednji. Gubitak konkurentske prednosti na tržištu
- 5. **Kredencijali zaposlenih** (korisnička imena i lozinke 10 000 zaposlenih, naročito administratorskih)
 - a. inherentna izloženost: zaposleni (podložni phishing napadima)
 - b. bezbednosni ciljevi:
 - i. poverljivost: kritična. Kompromitovani nalog predstavlja ključ za sve ostale nivoe imovine
 - c. uticaj: kritičan. Omogućava napadaču da se kreće kroz mrežu i pristupi bazi podataka

Zadatak 3 - Površina napada

Eksterni korisnici (klijenti): Web sajt, mobilna aplikacija, login, forme za unos podataka

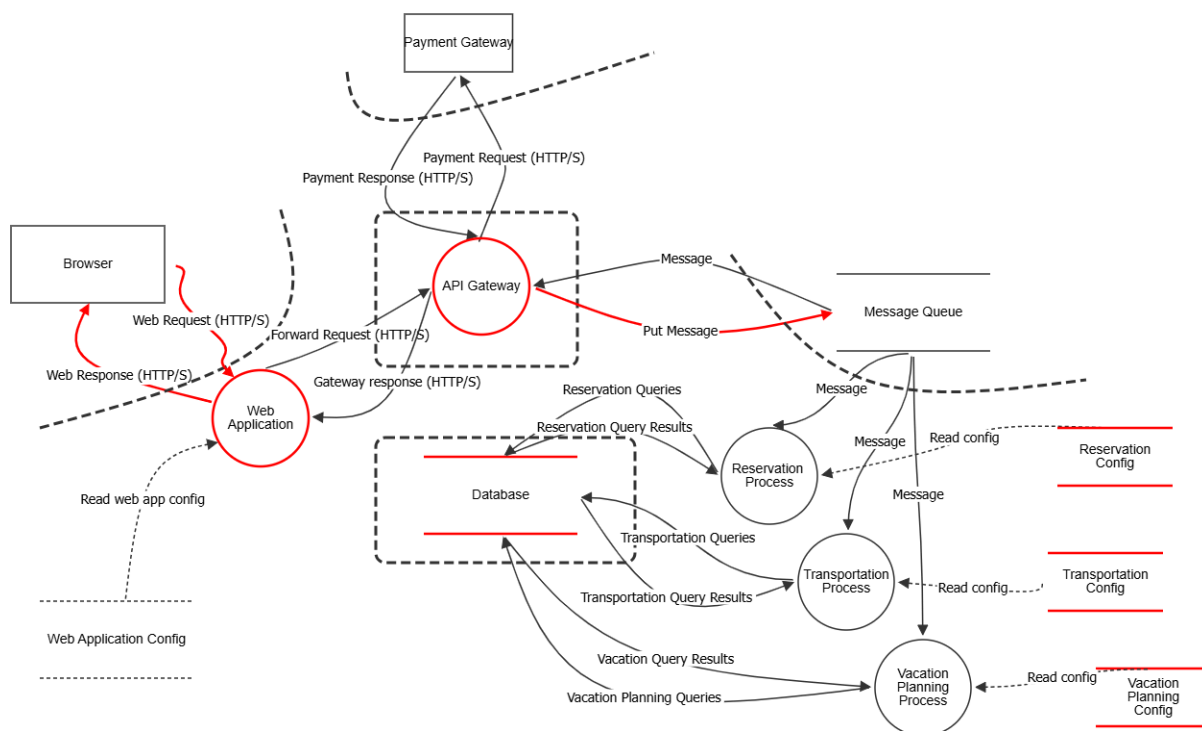
Interni korisnici (zaposleni): Admin panel, VPN, analiticki/komunikacioni alati

Partneri (hoteli, avio-kompanije...): partner API

Plaćanja: integracija sa payment servisima, obrada kartica i transakcija

Infrastruktura: cloud platforme, serveri, kontejneri

Zadatak 4 - Data Flow Diagram



Zadatak 5 - STRIDE analiza i mitigacije

1. API Gateway

a. Threat A

- i. **Threat Title:** Transaction Repudiation
- ii. **Type:** Repudiation
- iii. **Description:** A user or the system could deny that a payment transaction was authorized or processed due to insufficient evidence.
- iv. **Mitigation:** Implement digital signatures for all outgoing requests and maintain a tamper-proof audit log for all transaction state changes.

b. Threat B

- i. **Threat Title:** Broken Object Level Authorization (BOLA)
- ii. **Type:** Elevation of Privilege
- iii. **Description:** An attacker manipulates the ID of a resource (e.g., a reservation ID) in the API request to access or modify data belonging to another user.
- iv. **Mitigation:** Implement strict authorization checks at the Gateway or Service level to ensure users can only access their own resources.

2. Web Application

a. Threat A

- i. **Threat Title:** Cross-Site Scripting (XSS) via Malicious Input
- ii. **Type:** Tampering
- iii. **Description:** An attacker injects malicious scripts into web pages viewed by other users by exploiting unsanitized input fields.
- iv. **Mitigation:** Implement strict server-side Input Validation and deploy a robust Content Security Policy (CSP).

b. Threat B

- i. **Threat Title:** Broken User Authentication
- ii. **Type:** Spoofing
- iii. **Description:** An attacker uses brute force or credential stuffing to gain access to a legitimate user's session, potentially compromising client data.
- iv. **Mitigation:** Implement multi-factor authentication (MFA) and account lockout policies after several failed attempts.

3. Put Message (Data Flow)

- a. **Threat Title:** Message Queue Flooding
- b. **Type:** Denial of Service
- c. **Description:** An attacker floods the message queue with a massive volume of requests, causing a system bottleneck and halting reservations.
- d. **Mitigation:** Implement Rate Limiting and Throttling at the API Gateway to restrict the number of messages processed per second.

4. Database (Data Store)

a. Threat A

- i. **Threat Title:** Mass Data Theft (PII Leak)
- ii. **Type:** Information Disclosure
- iii. **Description:** An attacker gains access to database files, leading to a massive leak of 100 million customer records (high GDPR risk).
- iv. **Mitigation:** Enforce Encryption at Rest (TDE) and implement strict Role-Based Access Control (RBAC).

b. Threat B

- i. **Threat Title:** Database Record Manipulation
- ii. **Type:** Tampering
- iii. **Description:** An attacker modifies prices or deletes reservations by exploiting vulnerabilities to alter database records.
- iv. **Mitigation:** Use Prepared Statements (Parameterized Queries) and enforce strict input validation at the application level.

c. Threat C

- i. **Threat Title:** Query-Based Denial of Service (ReDoS/DB-DoS)
- ii. **Type:** Denial of Service

- iii. **Description:** An attacker sends specially crafted, extremely complex search queries (e.g., searching for 100 million records without filters) that consume all CPU/RAM resources of the database, crashing the booking system.
 - iv. **Mitigation:** Implement **Query Timeouts**, Pagination (limiting the number of results per page), and Database Indexing to ensure fast execution of frequent searches.
- 5. **Reservation/Transportation/Vacation Config**
 - a. **Threat A**
 - i. **Threat Title:** Credential Leakage in Plaintext
 - ii. **Type:** Information Disclosure
 - iii. **Description:** Database passwords and API keys are stored in plaintext within config files, making them accessible to unauthorized users.
 - iv. **Mitigation:** Move all sensitive secrets to an external Secret Vault (e.g., HashiCorp Vault or Azure Key Vault) or use encrypted Environment Variables.
 - b. **Threat B**
 - i. **Threat Title:** Unauthorized Configuration Modification
 - ii. **Type:** Tampering
 - iii. **Description:** An attacker with local access modifies configuration files to redirect data flows or lower security thresholds (e.g., turning off SSL validation).
 - iv. **Mitigation:** Use File Integrity Monitoring (FIM) to alert on unauthorized changes and restrict file system permissions to "Read-Only" for the processes.
- 6. **Web Response**
 - a. **Threat Title:** Sensitive Data Leakage in HTTP Headers
 - b. **Type:** Information Disclosure
 - c. **Description:** Server headers or verbose error messages disclose technology stack details (e.g., Spring Boot version) or internal IP addresses to the attacker.
 - d. **Mitigation:** Configure the application to suppress detailed error messages and remove unnecessary headers (e.g., "X-Powered-By").
- 7. **Message Queue**
 - a. **Threat Title:** Unauthorized Message Consumption
 - b. **Type:** Information Disclosure
 - c. **Description:** If the queue is not properly secured, an internal attacker could read messages containing booking details.
 - d. **Mitigation:** Enable Access Control Lists (ACLs) for the Message Queue and encrypt the message body.
- 8. **Vacation Planning Queries and Reservation Queries**
 - a. **Threat Title:** Unauthorized Data Access via ID Manipulation
 - b. **Type:** Tampering (ili Information Disclosure)
 - c. **Description:** An attacker could modify the query parameters (like `reservation_id` or `customer_id`) to view or change travel bookings that do not belong to them.
 - d. **Mitigation:** Implement strict **Object-Level Authorization**. Ensure the system checks if the logged-in user actually owns the reservation before executing the database query.
- 9. **Transportation Queries**
 - a. **Threat Title:** SQL Injection in Search Filters
 - b. **Type:** Tampering
 - c. **Description:** An attacker inputs malicious SQL code into search filters (e.g., searching for a destination like `' OR 1=1 --`) to bypass authentication or dump the entire list of available flights and prices.
 - d. **Mitigation:** Use **Parameterized Queries** (Prepared Statements) and avoid any string concatenation when building database queries.
- 10. **Message (from Message Queue to Reservation Process)**
 - a. **Threat Title:** Message Replay Attack
 - b. **Type:** Tampering
 - c. **Description:** An attacker captures a valid "Booking Confirmed" message and sends it multiple times to the Reservation Process, causing duplicate bookings or double-charging the customer.
 - d. **Mitigation:** Implement **Idempotency** (checking if a message ID has already been processed) and use unique nonces/timestamps for every message.
- 11. **Reservation Process**
 - a. **Threat Title:** Business Logic Flaw in Reservation Handling
 - b. **Type:** Tampering
 - c. **Description:** An attacker manipulates the process to bypass payment verification, allowing them to confirm a reservation without a successful transaction from the Payment Gateway.
 - d. **Mitigation:** Strict server-side verification of payment status before finalizing any reservation in the database.

12. Transportation Process

- a. **Threat Title:** External API Resource Exhaustion (DoS)
- b. **Type: Denial of Service**
- c. **Description:** If the process is flooded with requests, it could exceed the API limits of external flight providers, causing the MegaTravel system to be blocked by partners.
- d. **Mitigation:** Implement **Circuit Breakers** (e.g., Resilience4j) to prevent cascading failures and manage external API quotas.

13. Vacation Planning Process

- a. **Threat Title:** Unauthorized Access to Vacation Packages
- b. **Type: Elevation of Privilege**
- c. **Description:** A low-privileged user or an external attacker gains access to the "Planning" logic to modify premium vacation packages or see private itineraries of VIP clients.
- d. **Mitigation:** Enforce **Role-Based Access Control (RBAC)** to ensure only authorized staff or the specific customer can access planning details.